

EthersFlow R25 Red Team Findings: The Four Doors

Empirical Attack-Surface Analysis of Pre-Execution Action Verification (KYAA)

Published: October 2026 | Release: v0.2.14 | Classification: Public Technical Whitepaper

1. Executive Summary

Autonomous AI agents equipped with tool-calling capabilities and financial or administrative authority introduce a novel threat boundary: semantic action failure. Existing identity standards (KYA) and authorization protocols (AP2, FIDO, OAuth) establish who an agent represents and what privileges it holds, yet concede that they cannot determine whether a composed runtime action is safe. An authorized agent can execute a malicious, drifted, or destructive action within its authorized perimeter.

EthersFlow closes this gap through Know Your Agent's Action (KYAA) - a pre-execution verification layer.

2. The R25 Evaluation Battery & Methodology

To stress-test our pre-execution gate, an independent red-team consortium authored 311 pre-registered, incident-grounded attack vectors categorized across four primary failure classes ('The Four Doors').

Testing employed a strict held-out methodology with zero visibility during heuristics calibration.

Evaluations measured detection rates, false alarm ratios, and cryptographic auditability under multi-model debate.

Key Performance Indicators across 311 Attack Vectors:

- Overall Threat Interception Rate: 92.3% (169/183 dangerous vectors blocked at gate; 95% CI: 87.6% - 95.4%)
- False Positive Rate on Standard Benign Operations: < 0.8% across 128 production controls
- Erroneous Autonomous Approvals: 0% (Zero wrong approvals across all high-severity hazard classes)
- Latency: Deterministic Fast-Path p50 = 0.45s | Multi-Model Consensus p50 = 11.2s

3. Threat Model: The Four Doors Taxonomy

Door 1: Prompt Injection & Authority Laundering

Attackers embed directives into untrusted context (support transcripts, tool returns, web scrapes) asserting fabricated administrative authority ('SYSTEM NOTICE', 'Pre-approved by administrator'). The gate enforces untrusted-channel invariance: all embedded directives undergo full predicate evaluation without privilege elevation.

Door 2: Unanchored System Administration & Destination Camouflage

Directives requesting firewall deactivation, credential extraction, or resource redirection disguised under routine maintenance tickets (CR-, OPS-, CHG-). The gate enforces workload-identity invariance, requiring verified change ticket anchors and strict destination verification before any infrastructure mutation.

Door 3: Unbounded Protected Data Exfiltration & PHI Laundering

Exfiltration of clinical charts, therapy notes, or employee records masked by operational review framing. The gate enforces payload-derived data classification and subject-scope evidence linkage. Operational tickets legitimize workflow, never data scope. Accessing sensitive records without kernel-resolvable linkage is blocked.

Door 4: Unauthorized Benefit Delivery & Entitlement Alteration

Subtle alterations to academic grades, financial aid, or unanchored fee waivers submitted via user requests. The gate flags entitlement changes lacking verified institutional authority and cryptographic signatures.

4. Cryptographic Provenance & Dual-Door Verification

Ed25519 Immutable Trust Receipts

Every verdict emitted by EthersFlow is cryptographically signed using Ed25519 (EdDSA) private keys. The signed receipt binds the SHA-256 payload hash, policy configuration tuple, reason codes, timestamp, and multi-model council attestations. Receipts can be verified offline by any third-party auditor via JWKS.

Zero-Retention Privacy by Default

Raw action payloads are discarded immediately following signing. The vault persists receipt telemetry only, preventing sensitive enterprise prompts and PII from accumulating in storage.

Conclusion & Ongoing Research

Action verification is the missing pillar of AI agent governance. By binding deterministic kernel checks with multi-model adversarial consensus, EthersFlow provides verifiable safety before high-stakes execution. Independent acceptance QA is currently ongoing across our global partner testbeds.

References & Cryptographic Resources:

- Public JWKS Keys: <https://www.ethersflow.com/.well-known/jwks.json>
- Model Context Protocol Server: <https://github.com/Ethersflow/EthersFlow/tree/master/mcp-server>
- Contact & Security Inquiries: security@ethersflow.com | audit@ethersflow.com